COMPUTER SYSTEM VALIDATION AND QUALIFICATION POLICY

POL-006 | Issued under the Information Management Framework

Document ID: POL-006
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Chief Information Officer / Head of Quality Assurance
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Computer System Validation and Qualification Policy
Document ID	POL-006
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	CIO / Head of Quality Assurance
Custodian	Quality Assurance / Information Security
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	21 CFR Part 11, EU Annex 11, EMA Guideline on Computerised Systems (2011), ISPE GAMP 5 (2022), ICH Q10, GxP, SOX (IT General Controls), ISO/IEC 27001:2022

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This Policy establishes the requirements for demonstrating that computer systems at [Company Name] are fit for their intended purpose — that they do what they are designed to do, consistently, reliably, and in accordance with applicable regulatory and business requirements.

The rigour of these requirements is explicitly proportionate to the regulatory status and criticality classification of the system. Not all systems require formal Computer System Validation (CSV). The validation and qualification framework defined in this Policy applies four distinct assurance tracks — from full regulatory validation for GxP systems through lightweight testing assurance for low-criticality operational systems — ensuring that effort is directed where risk is highest.

> **NOTE:** This Policy deliberately distinguishes between CSV (a formal regulatory requirement for GxP systems) and System Qualification (a structured assurance approach for non-GxP systems). Applying CSV methodology to every system regardless of its regulatory status would be disproportionate, costly, and counterproductive. The correct track for each system is determined by its classification under POL-005.

2. Scope

This Policy applies to all computer systems — including software, hardware, infrastructure, cloud services, and hybrid systems — used at [Company Name]. The scope of obligations for any individual system is determined by its classification under POL-005 (System Classification Policy) and the regulatory flags assigned during that classification process.

Systems in scope include but are not limited to: laboratory information management systems (LIMS), electronic data capture (EDC) platforms, clinical trial management systems (CTMS), manufacturing execution systems (MES), enterprise resource planning (ERP) systems, quality management systems (QMS), document management systems (DMS), HRIS platforms, IT infrastructure (servers, network, cloud), and SaaS business applications.

Third-party systems and SaaS platforms used to support [Company Name] operations are in scope. The validation or qualification obligations for a third-party system are determined by the same classification criteria applied to internal systems. The System Owner retains accountability for ensuring that third-party systems used in regulated activities are appropriately validated, with evidence available for inspection.

3. Assurance Track Framework

Every system classified under POL-005 is assigned to one of four assurance tracks. Track assignment is determined at classification and drives all subsequent validation, qualification, and change management obligations. The track is reviewed whenever the system's classification is reviewed.

Track	Applies To	Assurance Approach	Regulatory Basis
Track A Full CSV / CSA	Any system carrying a GxP regulatory flag (GMP, GLP, GCP, GDP, GPvP) regardless of criticality tier. Also applies to: any system that generates, processes, stores, or transmits electronic records subject to 21 CFR Part 11 or EU Annex 11.	Computer System Validation (CSV) or Computer Software Assurance (CSA) per GAMP 5 (2022). Full validation lifecycle: User Requirements Specification (URS), risk assessment, supplier assessment, Installation Qualification (IQ), Operational Qualification (OQ), Performance Qualification (PQ), formal release, and continued process verification. For modern/agile systems: CSA approach using risk-based testing, critical thinking documentation, and objective evidence of fitness for purpose. IQ/OQ/PQ may be replaced by equivalent documented evidence of system performance.	21 CFR Part 11 EU Annex 11 GAMP 5 (2022) ICH Q10 EMA Computerised Systems Guideline
Track B SOX IT General Controls	Any system carrying a SOX regulatory flag and not carrying a GxP flag. Typically: ERP systems, financial reporting platforms, consolidation tools, access management systems supporting financial close.	ITGC documentation and evidence package: documented system requirements, configuration baseline, access control documentation, change management evidence, backup and recovery evidence, system availability monitoring. No formal IQ/OQ/PQ required. Controls tested annually as part of SOX ITGC programme.	SOX Section 404 PCAOB AS 2201 ISO/IEC 27001:2022
Track C Structure d Qualificati on	Tier 1 or Tier 2 systems (per POL-005) that carry no GxP or SOX regulatory flag. Typically: core IT infrastructure, security systems, ERP modules not in SOX scope, HR systems, critical business applications.	Structured qualification: User Requirements Specification (URS) or equivalent requirements documentation, test plan, test execution evidence (with pass/fail results), known issues register, and formal sign-off by System Owner and Information Security. No formal IQ/OQ/PQ or regulatory submission required. Proportionate to business criticality — sufficient to demonstrate fitness for purpose and to support incident investigation.	ISO/IEC 27001:2022 Internal policy baseline
Track D Lightweig ht Testing Assuranc e	Tier 3 and Tier 4 systems (per POL-005) that carry no GxP or SOX regulatory flag. Typically: collaboration tools, low-	Lightweight assurance: documented acceptance testing evidence confirming the system performs its intended function before deployment. A formal requirements specification is not	Internal policy baseline

Track	Applies To	Assurance Approach	Regulatory Basis
	criticality business applications, internal wikis, project management tools.	required, but test outcomes and deployment approval must be documented. Patch and update testing: confirmation that significant updates have been tested before deployment to production.	

GxP: Track assignment is determined by the most demanding applicable flag. A system that is both GxP-flagged and SOX-scoped is always Track A. A system that is SOX-scoped and Tier 2 is Track B (SOX overrides Track C). If in doubt about track assignment, consult Compliance / QA.

4. Track A — Computer System Validation and Assurance (GxP Systems)

4.1 Validation Lifecycle

All Track A systems must be managed through a documented validation lifecycle. The lifecycle encompasses: system selection and supplier assessment, specification, risk assessment, qualification or assurance testing, formal release, and continued process verification throughout the system's operational life. The lifecycle must be documented in a Validation Plan (VP) approved by Compliance / QA before validation activities commence.

Lifecycle Phase	Description	Required Documentation
System Selection and Supplier Assessment	Evaluate the system's fit for purpose against GxP requirements before acquisition. For vendor-supplied systems: conduct a supplier audit or supplier questionnaire to confirm the vendor's quality management system and their approach to software development and testing.	Supplier Assessment Report or Supplier Audit Report. For GAMP Category 4/5 systems: supplier questionnaire at minimum; audit for high-risk or novel systems.
User Requirements Specification (URS)	Define what the system must do from the user's perspective — functional, performance, security, compliance, and data integrity requirements. The URS must explicitly capture all regulatory requirements (e.g., 21 CFR Part 11 audit trail, electronic signature, data integrity controls). The URS is the foundation for all subsequent testing.	URS — approved by System Owner, Data Owner, and Compliance / QA.
Risk Assessment	Identify and assess the risks to data integrity, product quality, and patient safety arising from the system and its use. Apply the GAMP 5 risk framework. Determine which URS requirements are critical (directly linked to regulatory obligations or patient safety) vs. non-critical. Direct testing effort to critical requirements.	System Risk Assessment — approved by Compliance / QA.
Design / Configuration Specification	For configurable systems (GAMP Category 4): document the system configuration and customisations. For bespoke systems (GAMP Category 5): document the design	Functional / Design / Configuration Specification as appropriate.

Lifecycle Phase	Description	Required Documentation
	specification.	
Installation Qualification (IQ)	For traditional CSV: verify that the system is installed correctly per the vendor's specification and the site's infrastructure requirements. For CSA: provide objective evidence of correct installation. May be vendor-executed with review by [Company Name] Compliance / QA.	IQ Protocol and Report (or equivalent CSA evidence).
Operational Qualification (OQ)	For traditional CSV: test the system against the URS requirements — confirm it performs as specified under defined conditions. For CSA: risk-based testing focused on critical requirements with documented objective evidence. All critical URS requirements must be tested. Non-critical requirements may be tested by sampling. All failures must be documented and resolved before proceeding.	OQ Protocol and Report (or equivalent CSA test evidence).
Performance Qualification (PQ)	For traditional CSV: demonstrate that the system performs consistently in the production environment under realistic operating conditions, with real or representative data. For CSA: operational performance evidence from parallel running, pilot, or controlled rollout. May be combined with OQ for lower-risk systems where justified in the Validation Plan.	PQ Protocol and Report (or equivalent).
Formal Release for GxP Use	Compliance / QA issues a formal release decision — a written confirmation that validation is complete and the system is approved for GxP use. The system must not be used for GxP activities before this release. The release is recorded in the Validation Master File (VMF).	Release Decision / System Release Certificate.
Continued Process Verification	Ongoing monitoring of system performance post-release: periodic review of audit trails, user feedback, system logs, deviations, and change records. Annual review of validation status.	Annual Validation Status Review. Deviation / change records.

Lifecycle Phase	Description	Required Documentation
	Triggered re-validation on significant change (see Section 4.3).	

4.2 GAMP 5 Software Categories

GAMP 5 (2022) categorises software by the level of configurability and customisation, which determines the depth of validation effort required:

Category	Description	Examples	Validation Approach
Cat 1 Infrastructure Software	Operating systems, databases, middleware — not validated as GxP systems in their own right but must be qualified to support validated applications running on them.	Windows Server, Oracle DB, Linux	Qualification of the infrastructure layer. Confirmation that the environment is stable, patched, and tested before validated applications are deployed.
Cat 3 Non-Configured Products	Commercial off-the-shelf software with no configuration or customisation.	Simple measurement instruments, spreadsheet templates	Thorough testing against URS. Supplier assessment. No configuration documentation required.
Cat 4 Configured Products	Commercial software configured to meet specific user requirements. Configuration is the primary source of risk.	LIMS, EDC, QMS, DMS, ERP	Configuration specification required. Validation testing focuses on configured functionality and critical workflows. Regression testing after configuration changes.
Cat 5 Customised / Bespoke	Custom-developed software or heavily customised commercial software.	Custom-built LIMS modules, bespoke reporting tools	Full software development lifecycle documentation required. Source code review may be required. Highest validation rigour.

4.3 Change Control for Track A Systems

Any change to a Track A system — including software updates, configuration changes, infrastructure changes, or user access changes — must be managed through the change management process defined in POL-007. The impact on validation status must be assessed for every change:

Change Impact Level	Description	Validation Response
No Impact	Change does not affect validated functionality, data integrity controls, or GxP-relevant configuration.	Document the impact assessment. No re-testing required. Update validation documentation where change affects supporting documentation.
Minor Impact	Change affects non-critical functionality or configuration that does not directly affect GxP data or audit trail.	Regression testing of affected area. Update OQ/PQ records. Compliance / QA review of change evidence.
Major Impact	Change affects critical functionality, audit trail configuration, electronic signature, or GxP data flows.	Formal re-validation of affected areas. Updated URS / configuration specification. OQ/PQ re-testing of all affected critical requirements. New release decision from Compliance / QA.
System Replacement	The system is replaced with a new system.	Full validation lifecycle for the new system. Data migration validation required if data is migrated from the old system.

4.4 Validation Master File

Each Track A system must have a Validation Master File (VMF) — a single controlled location (physical or electronic) where all validation lifecycle documentation is maintained. The VMF must be accessible to regulatory inspectors on request and must include or reference: the Validation Plan, all qualification protocols and reports, the system risk assessment, the URS, supplier assessment records, the release decision, change records, and the current validation status.

IMPORTANT: The VMF must be maintained throughout the system's operational life and for the applicable retention period after decommissioning (see POL-002 Table 5.1 — CSV documentation: life of system + 5 years). FDA and EMA inspectors will request access to VMFs during GxP inspections.

4.5 21 CFR Part 11 and EU Annex 11 Compliance

Systems that generate, process, store, or transmit electronic records subject to 21 CFR Part 11 (US) or EU Annex 11 must additionally demonstrate compliance with:

- Audit trail: automatically recorded, time-stamped, immutable, reviewed periodically — per POL-003 and SOP-003
- Electronic signatures: unique to one individual, linked to the record, with printed name, date/time, and signature meaning — per POL-003
- System access controls: individual user accounts, role-based access, automatic log-out — per POL-008
- Data backup and recovery: validated backup and recovery procedures, tested per system criticality tier

- Audit trail integrity: the audit trail itself must be protected against modification and must be retained alongside the records it relates to

Compliance with Part 11 / Annex 11 must be demonstrated as part of the Track A validation — it is not a separate exercise. The URS must capture all Part 11 / Annex 11 requirements, and the OQ must test them.

5. Track B — SOX IT General Controls (Non-GxP SOX Systems)

Track B applies to systems in scope for SOX ITGC that do not carry a GxP regulatory flag. The objective is to provide auditable evidence that IT controls supporting financial reporting are designed and operating effectively — not to achieve a validated state in the GxP sense.

ITGC Domain	Required Evidence	Responsible
Change Management	Evidence that all changes to in-scope systems are authorised, tested, and approved before deployment to production. Change log maintained. Emergency changes documented retrospectively. Aligns with POL-007.	System Owner / IT
Logical Access	User access list with roles. Evidence of access provisioning and deprovisioning controls. Quarterly access reviews. Privileged access controls. Aligns with POL-008 and POL-009.	System Owner / Information Security
Computer Operations	Evidence of: system availability monitoring, batch job monitoring, backup execution and testing, incident and problem management records.	Data Custodian (IT)
Program Development	Evidence that new functionality is developed, tested, and approved in a controlled environment before production deployment. SDLC controls.	System Owner / IT
System Configuration Baseline	Documented current configuration of in-scope systems. Evidence of baseline protection against unauthorised change.	Data Custodian (IT)

Track B controls are tested annually as part of the SOX ITGC testing programme, coordinated by Compliance / QA. Evidence must be retained for 7 years per POL-002 Section 5.2.

6. Track C — Structured Qualification (Critical Non-Regulated Systems)

Track C applies to Tier 1 and Tier 2 systems that carry no GxP or SOX regulatory flag. The objective is to demonstrate that the system is fit for its intended purpose and that there is sufficient evidence to support incident investigation, root cause analysis, and continuity planning — without the overhead of formal regulatory validation.

Component	Requirements
Requirements Documentation	A User Requirements Specification (URS) or equivalent functional requirements document defining what the system must do, including performance, security, and availability requirements. Must capture POL-005 Tier-mandated technical controls (encryption, monitoring, backup, DR targets).
Test Plan	A documented test plan identifying the tests to be executed before deployment, referencing each functional requirement. Tests must confirm: all critical functions operate as expected; security controls are in place and functioning; backup and recovery can be executed within defined RTO.
Test Execution Evidence	Documented evidence of test execution: test script (or description), expected result, actual result, pass/fail. All failures must be recorded as known issues with a remediation plan before go-live. No critical test failures may be left unresolved at go-live.
Known Issues Register	A register of all non-critical issues identified during testing that will be addressed post-deployment. Each item must have an owner, target resolution date, and risk assessment confirming that deployment is acceptable with the issue outstanding.
Formal Sign-Off	Written approval from the System Owner and Information Security confirming that testing is complete, known issues are acceptable, and the system is approved for production use.

Track C qualification documentation must be retained for the life of the system plus 5 years. It must be updated when a significant change is made to the system.

7. Track D — Lightweight Testing Assurance (Standard Operational Systems)

Track D applies to Tier 3 and Tier 4 systems with no GxP or SOX flag. The objective is to confirm that the system has been tested and accepted before production deployment — nothing more. Proportionality is the governing principle.

Requirement	Description
Acceptance Testing	The System Owner or a designated tester confirms that the system performs its core intended functions before deployment. Testing may be exploratory rather than scripted, but the outcome — the system works as intended — must be documented.
Deployment Approval	A written or email confirmation from the System Owner approving deployment to production. This may be lightweight but must exist — verbal approval is not acceptable.
Update Testing	Significant updates, version upgrades, or configuration changes must be tested in a non-production environment before deployment to production. The

Requirement	Description
	System Owner confirms the update has been tested and does not introduce adverse changes.
Issue Recording	Any significant issues identified during testing that affect the system's core function must be recorded and resolved before deployment. Minor issues may be tracked for post-deployment resolution.

8. Roles and Responsibilities

Role	Responsibility
Compliance / QA	Owns the Track A validation programme. Approves Validation Plans, risk assessments, and qualification protocols. Issues release decisions for GxP systems. Coordinates SOX ITGC testing for Track B. Reviews Track C sign-offs for Tier 1 systems.
System Owner	Accountable for their system's Track assignment. Ensures the appropriate validation or qualification activities are completed before system go-live. Signs off qualification for Track C/D. Maintains validation status through the system lifecycle.
Data Custodian (IT)	Executes technical qualification and testing activities. Maintains the infrastructure qualification layer for Track A systems. Provides configuration and environment evidence. Executes IQ protocols.
Information Security	Reviews and approves security requirements in URS for all tracks. Confirms security controls are in place at go-live for Track B/C. Provides input to Part 11 / Annex 11 assessment for Track A.
CIO	Approves this Policy. Accountable for the organisation's overall system assurance posture. Approves Track A validation programme resourcing.
Data Owner	Contributes data requirements and handling requirements to URS. Confirms data integrity requirements for Track A systems.
Validation Lead	Where designated: leads the Track A validation lifecycle for a specific system. Coordinates URS authorship, risk assessment, and testing. Reports validation status to Compliance / QA.

9. System Decommissioning

System decommissioning must be managed as a controlled activity regardless of track. The decommissioning plan must address:

- Data migration: confirmation that all data with a current retention period has been migrated to an approved successor system or archive per SOP-002
- Validation closure (Track A): a Validation Closure Report documenting that the system has been formally retired, all data has been migrated or disposed of, and the VMF is archived
- Data disposal: all data that has exceeded its retention period must be disposed of per SOP-002 before the system is decommissioned
- Access revocation: all user access must be revoked and the access revocation documented before shutdown
- Audit trail preservation: for Track A systems, audit trail records must be migrated or archived alongside the records they relate to — they must not be left in the decommissioned system

10. Third-Party and Cloud-Hosted Systems

Third-party and cloud-hosted systems are subject to the same track requirements as internally hosted systems. The following additional obligations apply:

10.1 Track A Third-Party Systems

- The System Owner must obtain and review the vendor's validation documentation (particularly the vendor portion of IQ/OQ) before [Company Name] performs its site-specific qualification
- A vendor audit or supplier questionnaire is required before first use of a Track A third-party system for GxP activities
- The contract / Data Processing Agreement must include provisions for: access to audit trail data, right to audit, vendor notification of changes that may affect validation status, data return or deletion on contract termination
- Vendor-executed software updates that affect validated functionality must be communicated to [Company Name] in advance with sufficient notice to plan and execute re-validation activities

10.2 All Tracks — Cloud and SaaS

- Cloud services used in any regulated capacity must be assessed under POL-013 (Third Party and Vendor Risk Policy) before deployment
- The physical and logical location of data must be confirmed — cross-border data storage may trigger requirements under POL-004 (Privacy Policy)
- Exit strategy: confirm that data can be extracted in a usable format at contract termination — data lock-in is a business continuity risk for Tier 1/2 systems

11. Exceptions and Waivers

Deviations from the requirements of this Policy require written approval from Compliance / QA (for Track A) or Information Security (for Track B/C/D). All exceptions must be documented with: the nature of the deviation, the risk assessment supporting the deviation, mitigating controls in place, the approver, and an expiry date. Exceptions must not compromise GxP data integrity or SOX ITGC control effectiveness.

> **IMPORTANT:** No exception may waive the requirement for an approved release decision before a GxP system is used for regulated activities. There is no regulatory risk acceptable enough to justify using an unvalidated system for GxP data.

12. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework
POL-003	Data Integrity Policy	ALCOA+ and audit trail requirements apply to all Track A GxP systems; this Policy defines how those systems are validated
POL-005	System Classification Policy	System classification (criticality tier and regulatory flags) determines track assignment under this Policy
POL-007	Change Management Policy	All changes to Track A/B/C systems must be managed through POL-007; change impact on validation status assessed per Section 4.3
POL-008	Access Control Policy	Part 11 / Annex 11 individual user account and access control requirements; access review cadence per system criticality tier
POL-009	Privileged Access Management Policy	Administrative access to GxP systems requires additional controls
POL-010	Information Security Risk Policy	System-level risk assessments are required pre-go-live for Track A/C; DIRA (SOP-003) is the GxP domain risk assessment feeding the IS Risk Register; risk treatment plans for system-level risks are implemented via this Policy's change control chain
POL-015	IT Service Management and Operational Incident Policy	Unplanned operational incidents on GxP systems are qualification events requiring VMF documentation; validated state must be confirmed by Compliance / QA before GxP restart after any operational outage; audit trail gaps during outages must be documented
POL-011	Business Continuity Policy	DR/recovery requirements per system criticality tier — validated backup and recovery for Track A systems
POL-013	Third Party and Vendor Risk Policy	Third-party system assessment before deployment; vendor audit requirements for Track A
POL-014	Audit Trail and Monitoring Policy	GxP system audit trail capability must be validated as part of Track A OQ; audit trail requirements (content, immutability, NTP sync, inspector accessibility) must be in the URS and

Document ID	Title	Relationship
		confirmed in OQ test scripts
SOP-002	Data Retention and Disposal Process	VMF retention (life of system + 5 years); data disposal on decommissioning
SOP-003	Data Integrity Process	DIRA mandatory for Track A systems; audit trail review schedule
EXC-001	Exception Management Policy and Register	GxP validation exceptions (e.g., overdue re-qualification) are Category 4 under EXC-001 — 6-month maximum, mandatory Compliance/QA involvement, VMF documentation required; operating an unvalidated GxP system is non-approvable per EXC-001 Section 5
RACI-001	Roles, Responsibilities and Authorities	Accountability for CSV/CSA and qualification activities

13. Definitions

Term	Definition
Computer Software Assurance (CSA)	The FDA's risk-based approach to assuring computerised systems are fit for intended use, emphasising critical thinking and objective evidence over prescriptive documentation. Introduced as an alternative to traditional CSV.
Computer System Validation (CSV)	The documented process of demonstrating — through objective evidence — that a computer system consistently does what it is designed to do in accordance with regulatory requirements. Required for GxP systems under 21 CFR Part 11 and EU Annex 11.
GAMP 5 (2022)	Good Automated Manufacturing Practice, 2nd edition. The industry standard framework for CSV/CSA, published by ISPE. Defines software categories and a risk-based approach to validation.
Installation Qualification (IQ)	Documented verification that the system and its subsystems have been installed correctly per the vendor and site requirements.
Operational Qualification (OQ)	Documented verification that the system operates as specified under defined conditions — typically testing against the URS.
Performance Qualification (PQ)	Documented verification that the system consistently performs as intended in the production environment under realistic operating conditions.
Validation Master File (VMF)	The controlled repository of all validation documentation for a single system, maintained throughout its lifecycle.
User Requirements Specification (URS)	The document defining what a system must do from the user's perspective, including all regulatory requirements. The foundation for all validation activities.

— End of Document —

POL-006 v1.0 DRAFT | [Company Name] | CONFIDENTIAL